

Kobayashi Maru — Document Pédagogique

Documentation complète de l'infrastructure — KM-M1-CDC-E · 2026

État du document (16/09/2026). Sections 1, 2, 3, 6 et 7 renseignées à partir de l'infrastructure réellement déployée et vérifiée (branche `work/integration-deploy`, 26 conteneurs sains sur `vu\ndb`, NAT OPNsense posé et testé depuis l'extérieur, 23 règles Suricata écrites et déployées sur `nsm`). Section 4/5 : chaîne A rejouée à 3/4 (preuve réelle) le 16/09/2026, chaîne B amorcée (E5), chaîne C arrêtée à E3 (indice E6 connu, exploitation `pwnscriptum` non aboutie). Section 8 (répartition nominative) renseignée.

1 Présentation de l'entreprise fictive et rappel du CDC choisi

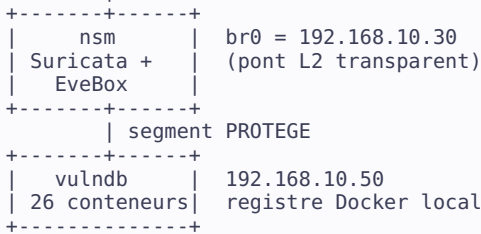
CHAMP	VALEUR
Entreprise fictive	MaisonVerte SAS — enseigne de jardinerie et décoration d'intérieur
Secteur	Retail / e-commerce omnicanal (jardinerie, décoration)
Profil CDC choisi	Profil E — Reconstruction du SI omnicanal MaisonVerte (réf. KM-M1-CDC-E)
Domaine interne / public	Public : <code>maisonverte.fr</code> (shop, api, vendeurs, cache) via OPNsense <code>10.85.4.10</code> . Interne : zones DMZ / SRV / DATA / USERS / ADMIN / SHOPS sur <code>192.168.10.0/24</code> côté groupe, réseaux Docker <code>172.30.0.0/16</code> côté <code>vu\ndb</code> .
Zone spécifique	SHOPS — consolidation des ventes magasin et WMS entrepôt (12 points de vente, 1 entrepôt logistique de référence)
Actifs critiques	1) chiffre d'affaires en ligne (40 % du CA) ; 2) données personnelles clients et historique des commandes ; 3) continuité de l'encaissement en magasin

MaisonVerte SAS (540 salariés, 12 points de vente en région, un entrepôt logistique, siège à Nantes) demande la reconstruction de bout en bout de son SI omnicanal — de la boutique en ligne jusqu'aux caisses de magasin — avant sa période commerciale de fin d'année. La boutique a été développée par une agence web externe (compte `agence.web` toujours actif), tandis que caisses et logistique sont gérées en interne ; les deux univers communiquent par traitements nocturnes et interfaces développées au fil de l'eau. Les magasins doivent pouvoir continuer à encaisser même si le lien vers le siège tombe. Périmètre inclus : services applicatifs, routeur périmétrique, segmentation, jeux de données de recette, supervision de sécurité, documentation. Périmètre exclu : terminaux de paiement bancaire réels (simulés), téléphonie, 11 des 12 magasins (un magasin de référence suffit).

2 Schéma réseau complet

Schéma détaillé disponible dans `suivi/schema-maisonverte.drawio`. Vue textuelle de la topologie physique et logique du lab (groupe G04) :

```
[autres groupes] --- segment EXPOSITION (10.85.4.0/24, un /24 par groupe, cloud-init)
                        |
                        +-----+
                        | poste d'attaque | eth0=exposition | OPNsense | 10.85.4.10 (WAN)
                        | 10.85.4.20 | | E1 (sain) | 192.168.10.1 (LAN)
                        +-----+
                        | eth1 = 192.168.10.10 (segment LAB) |
                        +-----+
```



Publication externe unique : 10.85.4.10:443 → NAT OPNsense → 192.168.10.50:443 , où E2 (nginx) termine le TLS et distribue par SNI/Host vers E2, E3, E4, E5.

Zones du socle (réseaux Docker sur vulndb)

ZONE	RÉSEAU DOCKER	SOUS-RÉSEAU	CONTENU
DMZ	net-dmz	172.30.10.0/24	E2, E3, E4, E5
SRV	net-srv	172.30.20.0/24	E6, E7, E8, E9, E14, E16
DATA	net-data	172.30.30.0/24	E10, E11
USERS	net-users	172.30.40.0/24	réservé (non utilisé par la tranche ferme actuelle)
ADMIN	net-admin	172.30.50.0/24	E15, ELK (Elasticsearch/Kibana/Filebeat défensifs)
SHOPS	net-spec	172.30.60.0/24	E12, E13

Micro-segments internes (un par maillon de chaîne, jamais publiés)

CHAÎNE	MICRO-SEGMENTS	MAILLONS COUVERTS
A	mv-a-edge , mv-a-core , mv-a-data	E2–E7, E7–E8, E8–E10
B	mv-b-edge , mv-b-core , mv-b-data	E5–E14, E14–E12, E12–E11
C	mv-c-edge , mv-c-core , mv-c-spec	E3–E6, E6–E9, E9–E13

3 Tableau d'inventaire

État vérifié le 16/09/2026 sur vulndb (docker ps) : 26 conteneurs actifs, tous healthy .

NOM DU CONTENEUR	RÉSEAU DOCKER	IMAGE	VERSION	PORTS	EXPOSITION
cache-dmz01 (E2)	net-dmz, mv-a-edge, mv-b-edge, mv-c-edge	vulhub/nginx	1	443	Publié — 192.168.10.50:443 , seul point public
shop-dmz01 (E3)	net-dmz, mv-c-edge	vulhub/wordpress	4.6	80	Interne, via E2
shop-dmz01-db	backend privé E3	mysql	5	3306	Interne uniquement
mobile-dmz01 (E4)	net-dmz	vulhub/nginx	1	80	Interne, via E2 (sain)
market-dmz01 (E5)	net-dmz, mv-b-edge	build local (Dockerfile Tomcat)	8.5.19 (vulhub/tomcat base)	8080	Interne, via E2
backoffice-srv01 (E6)	net-srv, mv-c-core	vulhub/ofbiz	18.12.10	8443	Interne
search-srv01 (E7)	net-srv, mv-a-edge, mv-a-core	vulhub/elasticsearch	1.4.2	9200	Interne
cache-srv01 (E8)	net-srv, mv-a-core, mv-a-data	vulhub/redis	4.0.14	6379	Interne
files-srv01 (E9)	net-srv, mv-c-core, mv-c-spec	vulhub/samba	4.6.3	445	Interne
catalog-data01 (E10)	net-data, mv-a-data	vulhub/postgres	10.7	5432	Interne

clients-data01 (E11)	net-data, mv-b-data	vulhub/mongo-express	0.53.0	8081	Interne
clients-data01-mongo	backend privé E11	mongo	3.4	27017	Interne uniquement
pos-consol-shops01 (E12, executor)	net-spec, mv-b-core	vulhub/xxl-job	2.2.0-executor	9999	Interne
pos-consol-shops01-admin (E12, admin)	net-spec	vulhub/xxl-job	2.2.0-admin	8080	Interne
pos-consol-shops01-db	backend privé E12	mysql	5.7	3306	Interne uniquement
wms-shops01 (E13)	net-spec, mv-c-spec	vulhub/struts2	2.3.30	8080	Interne
deploy-srv01 (E14)	net-srv, mv-b-edge, mv-b-core	vulhub/jenkins	2.441	8080	Interne
supervision-admin01 (E15, web)	net-admin	zabbix/zabbix-web-nginx-mysql	alpine-7.0.27	8080	Interne (sain)
supervision-admin01-server	net-admin	zabbix/zabbix-server-mysql	alpine-7.0.27	10051	Interne (sain)
supervision-admin01-db	backend privé E15	mariadb	11.4	3306	Interne uniquement
crm-srv01 (E16)	net-srv	nginx	1.27.4-alpine	80	Interne (sain)
elk-admin01-es	net-admin	docker.elastic.co/elasticsearch/elasticsearch	7.17.24	9200	Interne uniquement (défensif, distinct de E7)
elk-admin01-kibana	net-admin	docker.elastic.co/kibana/kibana	7.17.24	5601	Publié en loopback vulndb uniquement (127.0.0.1:5601), tunnel SSH requis
elk-admin01-filebeat	net-admin	docker.elastic.co/beats/filebeat	7.17.24	—	Interne, lit les logs Docker en lecture seule
tp-registry	infra TP (hors tranche ferme)	registre Docker local	—	5000	Interne au lab, fourni par la plateforme
tp-registry-ui	infra TP (hors tranche ferme)	IHM du registre	—	5001	Interne au lab, fourni par la plateforme

4

Fiches des services vulnérables

Champs techniques (image, CVE, niveau, vecteur) confirmés depuis le build. Colonnes *exploit validé / preuve* marquées *à renseigner* quand la chaîne n'a pas encore été rejouée sur le terrain à la date de ce document (voir §5 pour la chaîne A, déjà rejouée à 3/4).

Réf	Service	Image Vulhub	CVE / Faille	Niveau	Vecteur d'attaque	Exploit validé	Emplacement du flag
E2	Reverse proxy / cache	nginx/insecure-configuration	fuite d'info (alias mal configuré)	N1	Traversal / LFI via alias nginx, révèle la route de recherche interne	Oui — voir §5 chaîne A	flag_id=1 (flags.map), conteneur cache-dmz01
E3	Boutique WordPress	wordpress/pwnscriptum	RCE non authentifiée	N1	Exploit pwnscriptum, indice vers back-office E6	Tenté, non abouti — voir §5	flag_id=2, conteneur shop-dmz01
E5	Portail vendeurs Tomcat	tomcat/CVE-2017-12615	CVE-2017-12615	N1	PUT JSP non authentifié → webshell, indice Jenkins	Oui — voir §5 chaîne B	flag_id=3, conteneur market-dmz01
E7	Recherche produits	elasticsearch/CVE-2015-1427	CVE-2015-1427	N2	RCE Groovy non authentifiée, indice vers Redis	Oui — voir §5 chaîne A	flag_id=4, conteneur search-srv01
E8		redis/4-unacc	accès non authentifié	N2		Lecture confirmée	

	Cache sessions				Redis sans mot de passe, lecture d'un secret PostgreSQL	— RCE en cours (équipe attaque)	flag_id=5, conteneur cache-srv01
E10	Base catalogue / commandes	postgres/ CVE-2019-9193	CVE-2019-9193 (COPY FROM PROGRAM)	N3	Exécution de commande via COPY FROM PROGRAM avec le compte de service	à renseigner	flag_id=6, conteneur catalog-data01
E14	Déploiement Jenkins	jenkins/ CVE-2024-23897	CVE-2024-23897	N2	Lecture de fichier arbitraire via CLI non authentifiée, secret de job	à renseigner	flag_id=7, conteneur deploy-srv01
E12	Consolidation ventes	xxl-job/unacc	executor sans authentification	N3	RPC executor 9999 non authentifié, exécution de commande	à renseigner	flag_id=8, conteneur pos-consol-shops01
E11	Base clients	mongo-express/ CVE-2019-10758	CVE-2019-10758	N3	Injection NoSQL → RCE via \$where , ou creds par défaut admin/pass	à renseigner	flag_id=9, conteneur clients-data01
E6	Back-office commerçant	ofbiz/ CVE-2023-51467	CVE-2023-51467	N2	Contournement d'authentification via ProgramExport , indice partage E9	à renseigner	flag_id=10, conteneur backoffice-srv01
E9	Fichiers marketing	samba/ CVE-2017-7494	CVE-2017-7494 (is_known_pipename)	N2	RCE via partage accessible en écriture, procédure WMS trouvée	à renseigner	flag_id=11, conteneur files-srv01
E13	WMS entrepôt	struts2/s2-045	S2-045	N3	RCE via en-tête Content-Type (OGNL)	à renseigner	flag_id=12, conteneur wms-shops01

5 Chaînes de dépendance

Chaîne A — cache public → recherche → sessions → commandes

E2 → E7 → E8 → E10 — **3/4 étapes rejouées avec preuve réelle** le 16/09/2026 (détail complet : `documentation/04-exploitation.md`).

ÉTAPE	PRÉCONDITION	RÉSULTAT OBTENU	MÈNE À
E2	cache.maisonverte.fr publié via NAT E2	Traversal /files../ → lecture du runbook, révèle route + jeton de recherche	E7
E7	Route + jeton lus sur E2	RCE Groovy confirmée (id → uid=0(root)), indice Redis lu	E8
E8	Indice E7 validé	Pivot réseau via /dev/tcp , lecture Redis → credential PostgreSQL de service	E10
E10	Credential E8 obtenu	En cours (équipe attaque) — accès réseau E8→E10 confirmé disponible	fin de chaîne

Chaîne B — portail vendeurs → CI/CD → batch → clients

E5 → E14 → E12 → E11 — E5 exploité avec preuve réelle ; suite bloquée par une incompatibilité Java (voir note).

ÉTAPE	PRÉCONDITION	RÉSULTAT OBTENU	MÈNE À
E5	vendeurs.maisonverte.fr publié via E2	PUT JSP (CVE-2017-12615) confirmé → webshell, RCE id → uid=0(root)	E14
E14	Indice « deploy-srv01 » sur la page E5	Bloqué : E5 n'a que Java 8 (Tomcat 8.5.19/Debian 9), le CLI Jenkins 2.441 exige Java 11+	E12
E12	Secret E14	à renseigner	E11
E11	Credential E12	à renseigner	fin de chaîne

E3 → E6 → E9 → E13 — **arrêtée à l'étape E3** le 16/09/2026 (détail complet : `documentation/04-exploitation.md`).

ÉTAPE	PRÉCONDITION	RÉSULTAT OBTENU	MÈNE À
E3	<code>shop.maisonverte.fr</code> publié via E2	Indice back-office trouvé par simple lecture du site (article public, sans exploit). Exploitation pwnscriptum tentée (injection Host/PHPMailer-Exim) mais non concluante après plusieurs essais.	E6
E6	Indice E3 (connu)	<i>Non atteint — E6 n'est joignable que depuis un conteneur du réseau <code>mv-c-edge</code> (E3 uniquement)</i>	E9
E9	—	<i>Non atteint</i>	E13
E13	—	<i>Non atteint</i>	fin de chaîne

Blocage documenté : le vecteur pwnscriptum ne déclenche pas l'exécution attendue sur cette image (hypothèses : MTA incompatible avec la syntaxe Exim utilisée, timing de queue mail). Piste à reprendre pour débloquer la suite de la chaîne.

6 Comptes et accès

6a. Accès d'administration du lab (infrastructure)

Mots de passe volontairement omis de ce document versionné (rotés régulièrement par l'équipe) — voir le gestionnaire de secrets / canal privé de l'équipe pour les valeurs courantes.

SERVICE	COMPTE	MOT DE PASSE	RÔLE / DROITS	ZONE	COMMENTAIRE
OPNsense (webConfigurator)	root	— (canal privé équipe)	Administration complète du pare-feu du groupe	bordure (E1)	<code>https://192.168.10.1/</code>
Poste pivot / vulnDb / nsm	etudiant	— (canal privé équipe, un mot de passe distinct par hôte)	Utilisateur standard, sudo autorisé	segment LAB	SSH 22, RDP 3389 sur le poste
Poste pivot / vulnDb / nsm	root	— (canal privé équipe)	Superutilisateur	segment LAB	usage via sudo depuis <code>etudiant</code> de préférence

6b. Comptes applicatifs connus (par défaut Vulhub, intentionnellement faibles)

SERVICE	COMPTE	MOT DE PASSE	RÔLE / DROITS	ZONE	COMMENTAIRE
E3 WordPress — MySQL backend	root	root	Accès base <code>shop-dmz01-db</code>	DMZ (backend privé)	Défaut vulhub <code>wordpress/pwnscriptum</code> , non exposé hors conteneur
E10 PostgreSQL	postgres	postgres	Compte de service applicatif	DATA	Défaut vulhub <code>postgres/CVE-2019-9193</code> ; la faille elle-même permet <code>COPY FROM PROGRAM</code>
E11 mongo-express (IHM)	admin	pass	Accès IHM mongo-express	DATA	Défaut vulhub ; l'exploit CVE-2019-10758 ne nécessite pas nécessairement ce login (injection NoSQL)
E12 XXL-JOB — MySQL backend	root	root	Accès base <code>pos-consol-shops01-db</code>	SHOPS (backend privé)	Défaut vulhub <code>xxl-job/unacc</code>
E12 XXL-JOB executor (9999)	—	—	Aucune authentification (c'est la vulnérabilité)	SHOPS	RPC non authentifié
E6 OFBiz	—	—	Contournement d'authentification	SRV	CVE-2023-51467, <code>ProgramExport</code> avec identifiants vides
E14 Jenkins	—	—	Lecture fichier arbitraire non authentifiée	SRV	CVE-2024-23897 via CLI
E9 Samba	invité	—	Partage accessible	SRV	CVE-2017-7494, partage en écriture requis pour la RCE
E7 Elasticsearch	—	—	Aucune authentification (version 1.4.2)	SRV	CVE-2015-1427

E8 Redis	—	—	Aucune authentification	SRV	redis/4-unacc
E13 Struts2	—	—	RCE non authentifiée	SHOPS	S2-045, en-tête Content-Type
E2 nginx	—	—	Fuite d'info non authentifiée	DMZ	nginx/insecure-configuration

6c. Secrets générés au déploiement (pivots de chaîne)

Les identifiants de pivot découverts en cours de chaîne (ex. secret PostgreSQL révélé via Redis en chaîne A, token Jenkins révélé en chaîne B) sont générés à l'installation par `deploiement/00-infra/prepare-runtime-secrets.sh` (`openssl rand -base64 24`) et stockés uniquement dans `deploiement/state/secrets/` sur `vulnbd` (permissions `600` , répertoire exclu de Git). Ils ne sont jamais dupliqués dans le code, les fichiers `Compose` ni ce document ; leur valeur (masquée) est consignée au moment du rejeu de chaîne dans `documentation/04-exploitation.md` .

6d. Flags

Les 12 valeurs proviennent exclusivement de `enonce/flags-G04.csv` et sont mappées `service ↔ flag_id` dans `deploiement/config/flags.map` (ordre : E2, E3, E5, E7, E8, E10, E14, E12, E11, E6, E9, E13). Les valeurs elles-mêmes ne sont pas reproduites dans ce document ; seul l'emplacement (conteneur / montage) est indiqué en section 4.

6e. Comptes métier attendus par le CDC (annexe client, à cartographier)

COMPTE	RÔLE	ENTITÉ
f.leclerc	DSI	Informatique
n.rousseau	Responsable e-commerce	Marketing
a.perrot	Acheteur, gestion du catalogue	Achats
resp.mag001 ... resp.mag012	Responsables de magasin, accès back-office	Magasins
logistique.entrepot	Gestionnaire d'entrepôt	Logistique
svc_deploy	Compte de service — déploiement	—
svc_caisse	Compte de service — remontée des ventes	—
agence.web	Compte agence ayant développé la boutique, toujours actif	Externe
client_test	Compte client de démonstration	Externe
vendeur_test	Compte vendeur de démonstration	Externe

Ces comptes sont ceux exigés par le CDC (annexe 11) ; leur implémentation concrète dans `WordPress/back-office/portail vendeurs` reste à documenter précisément lors du rejeu de chaîne.

7 Configuration OPNsense et règles Suricata

7a. Règles OPNsense (publication et filtrage)

Interfaces : WAN `vtnet0` — `10.85.4.10/24` , passerelle `10.85.4.1` ; LAN `vtnet1` — `192.168.10.1/24` .

#	SOURCE	DESTINATION	PORT	ACTION	MOTIF MÉTIER
1	any (WAN)	wanip (<code>10.85.4.10</code>) → <code>192.168.10.50</code> (E2)	tcp/443	NAT port-forward, association filtre « pass »	Publication unique de la boutique/API/portail vendeurs/cache via le reverse-proxy E2 (SNI/Host)

Règle créée le 16/09/2026 (uuid `0c3808e8-de45-405e-8795-01e2396c1757`) via le `webConfigurator`. Aucune règle `Firewall > Rules > WAN` distincte n'a été nécessaire : l'association « pass » de la règle NAT autorise directement le trafic correspondant. Vérifié fonctionnel depuis l'extérieur (VPN) le 16/09/2026 : `shop.maisonverte.fr` , `api.maisonverte.fr` , `vendeurs.maisonverte.fr` , `cache.maisonverte.fr` répondent tous en HTTP 200 sur `10.85.4.10:443` . Aucune autre règle NAT/filter n'existe à ce jour (config `<filter>` vide par ailleurs) — cohérent avec le principe « rien n'est ouvert sauf ce qui est explicitement publié ».

7b. Règles Suricata

Écrites et déployées le 16/09/2026 sur `/etc/suricata/rules/tp-local.rules` (sonde `nsm`, `192.168.10.30`) : 23 règles ajoutées (SID 9000007 à 9000029) au-dessus des 6 règles socle fournies par la plateforme (SID 9000001-9000006, non modifiées). Validation `suricata -T` : 0 erreur. Rechargement : 52613 règles chargées au total, 0 échec.

Constat de test réel important. E2/E3/E5 sont publiés en TLS. Un test en direct a confirmé que les signatures de *contenu* HTTP (traversal, user-agent, canary...) ne se déclenchent pas sur ce trafic chiffré (limite technique, pas un bug — Suricata ne peut pas inspecter un corps TLS sans les clés de session). Pour compenser, 4 règles supplémentaires basées sur le **SNI TLS** (visible en clair dans le ClientHello) ont été ajoutées et **vérifiées déclenchées en conditions réelles** le 16/09/2026 à 10:58:48 (alertes `fast.log` pour `shop / vendeurs / cache.maisonverte.fr`, source `10.200.0.67` → `192.168.10.50:443`). C'est la détection réseau fiable pour le trafic N1 réel ; la preuve applicative détaillée (contenu de l'exploit) reste à chercher côté ELK/logs applicatifs, pas côté réseau, pour tout ce qui passe derrière E2. Détail complet par SID : `documentation/08-regles-suricata.md`.

Reste à faire : déclencher les règles restantes (pivots internes, DATA, canary) en conditions réelles lors du rejeu des chaînes A/B/C (section 4/5) et vérifier dans EveBox (`http://192.168.10.30:5636/`) avant la recette finale.

8 Répartition des tâches nominatif

MEMBRE	SERVICE(S) ALLOUÉ(S)	VULNÉRABILITÉ	CHAPITRE DE DOCUMENTATION	RÈGLE DE DÉTECTION
Nathan Palvadeau	E2-E6, E9, E13, E15, E16 (DMZ, chaîne C, services sains) + stack ELK + plan initial Suricata	nginx, wordpress, tomcat, samba, struts2	03-deploiement.md , 05-detection.md	Plan de SID initial (configure-suricata-notes.sh)
Thibault Foulon	Fondations infra (réseaux Docker, TLS, images offline), harnais de tests statiques, OPNsense (WAN/LAN/ interfaces)	—	00 à 04 (drafts), 06-recette.md	Vérification config OPNsense
Damien Aouaj	E7 (recherche produits), E8 (cache sessions), E14 (déploiement Jenkins) — chaîne A et amorce chaîne B	Elasticsearch CVE-2015-1427, Redis 4-unacc, Jenkins CVE-2024-23897	04-exploitation.md	SID 9000013-9000018
Yanis Hortholary	OPNsense (diagnostic + correction de la règle NAT WAN → E2), déploiement et test réel des 23 règles Suricata, validation exploitation E2/E5	nginx traversal (E2), Tomcat PUT (E5) — exploitation validée	07-endpoints-et-verification.md , 08-regles-suricata.md , Rendu/*	Écriture + déploiement SID 9000007-9000029, tests réels confirmés (EveBox/fast.log)
Adam Attafi	Validation des 3 chaînes d'exploitation (A/B/C) côté red team avant livraison ; préparation de l'attaque Phase 2 contre le groupe adverse ; chef de groupe / contact builder	Tests de rejeu sur l'ensemble des 12 vulnérabilités	06-recette.md	—
Seymen Isikli	Validation des 3 chaînes d'exploitation (A/B/C) côté red team avant livraison ; préparation de l'attaque Phase 2 contre le groupe adverse	Tests de rejeu sur l'ensemble des 12 vulnérabilités	06-recette.md	—